CyBOK

Penetration testing Introduction and Methods

Joakim Kävrestad
Jönköping School of Engineering
joakim.kavrestad@ju.se

© Crown Copyright, The National Cyber Security Centre 2023. This information is licensed under the Open Government Licence v3.0. To view this licence, visit https://www.nationalarchives.gov.uk/doc/open-government-licence/version/3/.

When you use this information under the Open Government Licence, you should include the following attribution: CyBOK memory analysis workshop slides © Crown Copyright, The National Cyber Security Centre 2023, licensed under the Open Government Licence: https://www.nationalarchives.gov.uk/doc/open-government-licence/version/3/.

Litterature note

- This lecture is based on the following CyBOK knowledge areas:
  - Malware and Attack Technologies
  - Adversarial Behaviours

- Additional material is cited throughout the lecture

Agenda

- Pentesting intro
  - Pentesting ”modes”
  - The hats
  - Ethics
- Rules of engagement
- Attack models
- How to pentest

Pentesting

- A simulated attack using the same tools and methods an adversary would use

- A common technique to test the security of an entity
  - Network
  - Device
  - Software
  - ….

Pentesting – general metod

- A pentest is essentially an attack, and follows an attack methodology
- As you can imagine, the attack methodology will differ depending on what target you are testing
- Lets look at a generic attack method

Pentesting – Info gathering

- The first step involved **information gathering** from open sources
  - **OSINT:** Open source intelligence

- This can include numerous different tasks all looking to gain information about the target
  - Google
  - Job adverts
  - Social media
  - …

Pentesting – Enumeration

CyBOK

- **Enumeration** is about scanning the target to know more about its technical properties

- Typical tasks include
  - Scanning IP ranges for responding hosts
  - Looking for open ports
  - Trying to figure out what software targets are running
  - ….

Pentesting – Exploitation

- **Enumeration** about finding and using vulnerabilities
- This is the step when we try to get access to systems – get a foothold
- Often involves using or building exploits

Pentesting – Priv Esc

- **Privilege Escalation** is all about expanding system access
- **Horizontal** means that you gain access to another account with similar permissions
- **Vertical** means that you get access to accounts with other different permissions (often higher)

Pentesting – Post-exploitation

CyBOK

- **Post-exploitation** is when a true attacker would realize their attack objectives

- As a pentester, you
  - Evaluate if you can use you access to target other hosts (pivoting)
  - See what additional information we can gather
  - Cover tracks
  - Report

REFLECT!

- Use one minute to write down one-liners which describe what you just learned – come up with as many as you can.
- Join up in pairs or groups and compare your lists for another minute.
- Questions so far?

Pentesting - modes

CyBOK

- A **black-box** test is when the pentester have no knowledge about the attack target
- A **grey-box** test is when the pentester have some knowledge about the attack target
- **White-box** means that the pentester have access to full knowledge such as internal documentation

Pentesting – black-box

- Most similar to a real attack
- Able to capture ” reconnaissance” aspects of an attack
- Often time-consuming, and expensive
- Since the pentester is unaware of how the target works, attack surfaces may be missed

Pentesting – grey-box

- Performed as an attack from the outside, but with some knowledge given to the pentester
- Can speed up the test and therefore limit costs
- Can also target the test on certain aspects of the test target

Pentesting – white-box

- Pentester will have full knowledge about the targets inner working
- Typically used for detailed testing of the functionality of the target and expected behavior
- Allows for the entire attack surface to be evaluated

REFLECT!

- Use one minute to write down one-liners which describe what you just learned – come up with as many as you can.
- Join up in pairs or groups and compare your lists for another minute.
- Questions so far?

Pentesting – Laws and ethics

- Pentesting is using hacking techniques
- Depending on how those skills are used, you are more or less lawful
- Even during an authorized test, you may come across information which is not meant for you

Pentesting – Hacker hats

- A **white-hat** is someone who use their skills for good and stay within the law

- A **gray-hat** typically use their skill for *their perception of* good. They do not follow laws or ethical standards if that conflicts with their objectives

- A **black-hat** is a criminal who seek some kind of gain, typically at the expense of others

Pentesting – ROE

- A **pentest** should be governed by a rules of engagement (ROE) document which outlines the playing-filed for the test in question

- The ROE should outline
  - Explicit **permission** to perform the test
  - The **scope** of the test (machines and systems)
  - **Rules,** such as permitted or forbidden techniques or what the pentester should do upon upon certain discoveries

REFLECT!

- Use one minute to write down one-liners which describe what you just learned – come up with as many as you can.
- Join up in pairs or groups and compare your lists for another minute.
- Questions so far?

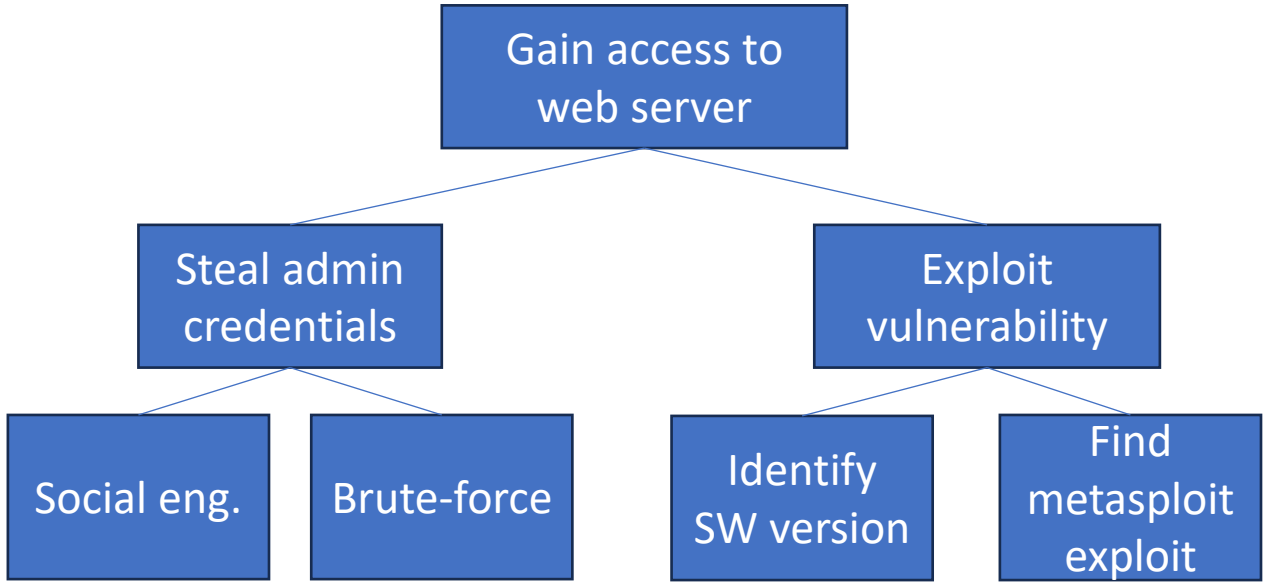
Pentesting – Attack models

- There are many models developed to describe attack processes
- Often designed to understand attackers rather than to help pentesters
- Still, a pentest is essentially an attack and those models can help☺

Pentesting – Attack tree

- An attack tree is a way to represent a certain malicious objective and different ways to achieve that objective.

- The objective is the top node and ways to reach the objective are represented as sub-nodes



Pentesting – Attack tree

- Using an attack tree, you model all possible ways to compromise a target
- It allows you to create a map and try possible attacks one by one
- Makes for a neat way to report your pentest

Pentesting – Cyber kill chain

- A kill chain is a model which outlines the phases of an attack
- The cyber kill chain was developed by the company Lockheed martin
- Models seven steps involved in malicious operations against computer systems

Pentesting – Cyber kill chain

- 1. Reconnaissance
  - Identify and select target. Often includes both OSINT and network scanning

- 2. Weaponization
  - Preparation of the attack payload
  - Involves getting or creating the weapons for the attack. Could mean downloading a tool or developing something own

Pentesting – Cyber kill chain

CyBOK

- 3. Delivery
  - Find a way to deliver the payload to the target
  - This can be phishing, drive by download or a direct network communication

- 4. Exploitation
  - Trigger the payload
  - Have it run somehow, this can be dependent on a user action (phishing) or using a vulnerability in the target

Pentesting – Cyber kill chain

- 5. Installation
  - Installation of a backdoor or Remote Access Trojan to maintain access
- 6. Command and Control (C2)
  - Establish infrastructure to enable C2 access to the compromised host
- 7. Actions on objectives
  - With access to the target device the attacker can fulfill her original objectives
  - Ransom, data exfiltration, …

Pentesting – Cyber kill chain

CyBOK

- The cyber kill chain is extensive and developed to describe sophisticated attacks
- It has been critiques as inflexible
  - In reality, attackers may skip or combine steps
- Should be seen as one of several tools

REFLECT!

- Use one minute to write down one-liners which describe what you just learned – come up with as many as you can.
- Join up in pairs or groups and compare your lists for another minute.
- Questions so far?

Pentesting – MITRE ATT&CK

CyBOK

- MITRE ATT&CK is described as a knowledge base and model for cyber adversary behavior

- Developed by MITRE which is a cybersecurity company, who also maintain the Common Vulnerabilities and Exposures (CVE) database
  - Dictionary of commonly known vulnerabilities

- Aims to reflect the phases and actions and attack may include

Pentesting – MITRE ATT&CK

CyBOK

- Oriented around tactics, which can be described as phases or goals
  - Reconnaissance, initial access, defense evasion, …
- Each tactic include techniques (which may have sub-techniques) which are actions within a tactic
  - Quite extensively described and exemplified

Pentesting – MITRE ATT&CK

CyBOK

- Divided into three technology domains
  - Enterprise
  - Mobile
  - Industrial Control Systems (ICS)

- Can be seen as an extensive library of techniques attackers *may* use

- Flexible in nature and does not impose a certain order of tactics

Pentesting – HOW?

- In house or consultant
  - Typically work for an employer

- Bug bounty
  - Companies post pentest assignment on open platforms
  - Registered users can complete the assignments and be rewarded
  - Several different platforms where some even offer training
    - intigriti
    - hackerone

Pentesting –Disclosure ethics

- As pentester you are likely to discover vulnerabilities
- On the one hand, those should be disclosed to the community for awareness and application of security measures
- On the other hand, they can't be immediately disclosed since malicious attackers can exploit them

Pentesting –Disclosure ethics

CyBOK

- To maximize both interest, it is typical to work under a responsible disclosure policy comprising the following steps
  - **Discovery** of a vulnerability
  - **Report** the vulnerability to the concerned vendor or organization
  - **Verification** of the vulnerability by the recipient
  - **Remediation** of the vulnerability by the vendor
  - **Disclosure** of the vulnerability once the fix is ready
- This only works if everyone follows the procedure
- Even if a vendor does not reply to a discovery report, it is custom to wait 60 -120 days before disclosing it

REFLECT!

- Use one minute to write down one-liners which describe what you just learned – come up with as many as you can.
- Join up in pairs or groups and compare your lists for another minute.
- Questions so far?

Thank you for today!

Additional reading

- https://www.splunk.com/en_us/blog/learn/cyber-kill-chains.html
- https://support.alertlogic.com/hc/en-us/community/posts/360023867491-The-Critical-Watch-Report-State-of-Threat-Detection-2018-is-here-
- https://attack.mitre.org/
- https://attack.mitre.org/docs/ATTACK_Design_and_Philosophy_March_2020.pdf
- https://www.hackerone.com/knowledge-center/why-you-need-responsible-disclosure-and-how-get-started